

Case Study — ISO/IEC 27001:2022 Implementation Project

Educational Institution (identity anonymized with organizational consent)

Prepared by: Tharaa Abo Alhassan | Information Technology Engineering Student

1. Project Overview

This case study summarizes a comprehensive information security assessment and remediation project delivered for a real educational institution, conducted under the applied cybersecurity track of an Information Technology Engineering program. All organization-identifying details (name, exact addressing, and granular findings) have been removed or generalized with the organization's consent; this document presents scope, methodology, and outcomes only.

The engagement followed the ISO/IEC 27001:2022 framework end-to-end: technical network assessment, governance documentation, physical security review, business continuity analysis, and staff security awareness training — covering the technical, administrative, and physical pillars of information security.

2. Scope of Work

- **Network Security Assessment** — on-site audit of an 8-floor building's network infrastructure; identified critical architectural weaknesses (flat network, no segmentation, no traffic monitoring).
- **Network Redesign** — re-architected the network using VLAN segmentation and Layer-3 switching to isolate traffic by function, deployable without additional hardware budget.
- **Risk Register** — 15 identified risks, scored and prioritized against ISO 27001:2022 controls.
- **Policies & Procedures Suite** — 15 formal security policies and 15 operating procedures covering identity management, data handling, incident response, backups, access control, and more.
- **Physical Security Assessment** — on-site audit across 7 control domains (visitor access, staff identification, server room security, CCTV, network equipment, document handling, BYOD).
- **Business Impact Analysis (BIA)** — RTO/RPO determination for the institution's critical business processes.
- **Security Incident Management Process** — defined intake, classification, response, and post-incident review workflow.
- **Data Handling Policy** — classification scheme and lifecycle controls (creation, storage, use, sharing, archival, destruction).
- **Employee Security Awareness Platform** — a live, bilingual e-learning platform built and deployed to train non-technical staff (see Section 5).

3. Deliverables Summary

Deliverable	Scope / Quantity
Network Assessment Report	Full infrastructure audit, 8-floor building
Network Redesign Proposal	4-VLAN segmented architecture
Risk Register	15 risks scored and prioritized
Security Policies	15 formal policies
Operating Procedures	15 documented procedures
Physical Security Assessment	7 control domains audited
Business Impact Analysis (BIA)	5 critical processes assessed
Awareness Training Platform	5 modules, 15+ videos, bilingual (AR/EN)

4. ISO/IEC 27001:2022 Controls Referenced

The project's findings and deliverables map to the following Annex A control areas:

Control	Area
A.5.12 / A.5.13 / A.5.14	Information classification, labeling, and transfer
A.5.15 / A.5.16 / A.5.18	Access control and identity management
A.5.26	Information security incident response
A.5.29	Business continuity — information security aspects
A.5.34	Privacy and protection of personal data
A.6.1 / A.6.7	Screening and remote working
A.7.2 / A.7.4 / A.7.5 / A.7.6	Physical entry, monitoring, and secure areas
A.7.7 / A.7.8 / A.7.14	Clear desk/screen, equipment siting, secure disposal
A.8.10 / A.8.13	Information deletion and backup
A.8.16	Monitoring activities (IDS/IPS)
A.8.20 / A.8.22	Network security and segmentation

5. Network Redesign — Before / After

The most critical finding was a completely flat network with no logical separation between staff, servers, and guest traffic. The proposed redesign addressed this directly:

Aspect	Before	After
Architecture	1 flat VLAN, unmanaged switching	4 segmented VLANs, Layer-3 switching
Core Switch	Unmanaged	Managed Layer-3 (inter-VLAN routing)
Internet Redundancy	Single satellite link	Primary + backup ISP link
Server Isolation	Shared with general user traffic	Dedicated isolated VLAN
Traffic Control	None	Trunk links + access-port VLAN assignment
DHCP	Single pool for all devices	Per-VLAN scoped DHCP pools

6. Employee Security Awareness Platform

As the project's staff-facing deliverable, a bilingual (Arabic/English) e-learning platform was designed and built from scratch to train non-technical employees on common cyber threats — phishing, password hygiene, malware, and social engineering — using short, 1–3 minute microlearning videos.

- 5 learning modules, 15+ short videos
- Live bilingual captions synced to video playback (Arabic/English)
- Automatic progress tracking and a 10-question final assessment with instant feedback
- Fully responsive design; hosted free on GitHub Pages
- Built with vanilla HTML5 / CSS3 / JavaScript — no external framework

Live platform: https://tharaacoder.github.io/CyberSecurity-Awareness-Course_for-employee/

7. Confidentiality Note

In line with the data classification and information handling principles applied throughout this project, the full deliverables — including the complete risk register, exact network addressing, detailed vulnerability findings, and the full text of all policies and procedures — are treated as confidential and are not published in full. This case study presents scope, methodology, and generalized outcomes only, consistent with responsible handling of a real organization's security posture. Full documentation is available for review on request (e.g., during an interview or technical discussion).